

# Sixth-Round Beginner-Fix Legal & Compliance Notice (v3.42)

**Document nature:** Compliance reminder for user account management / global search / attachments / per-user limit / business days / transcript / timezone. **Does not constitute legal advice.** Cumulatively applies to all §6 disclaimers in v3.25.10 → v3.41.

**Chinese version:** [POLISH\\_V342\\_LEGAL\\_NOTICE\\_ZH.md](#)

 **Customer MUST** have IT / legal / HR manager review before production use.

 **v3.42 includes structurally sensitive functions**

| Function                              | Risk Level                                                                                                    | Impact Scope             |
|---------------------------------------|---------------------------------------------------------------------------------------------------------------|--------------------------|
| User account create / deactivate (R1) |  System-wide access control | HR monthly + security    |
| Attach files to documents (R3)        |  Copyright / confidential  | Legal / internal control |
| AI per-user daily limit (R4)          |  Service level             | All staff                |
| Chat transcript export (R6)           |  User input history        | PII / trade secret       |
| Timezone setting (R7)                 |  Display layer             | All staff                |
| Global search (R2)                    |  Data visibility           | Internal control         |
| Business day calculation (R5)         |  Heuristic helper          | Sales                    |

## 1. User Account Management (R1) Most Security-Sensitive

### 1.1 Behavior

- LLM: "open account for Alice" → ConfirmCard → creates User row + links Employee
- LLM: "deactivate Alice's account" → ConfirmCard → User.is\_active = False
- No deletion (preserves audit trail)

## 1.2 Legal / Security Risks

### ● Permission and responsibility:

- Creating a superuser = **granting unrestricted system access**
- Deactivating an account = **immediately revoking employee access** (even mid-work-day)
- This operation's **legal meaning** equates to giving/taking back office keys

### ● Failure to deactivate timely risks:

- Departed employee with active account → may **continue operating** (data theft, record tampering)
- Violates PDPA Enforcement Rules §12 "data security measures"
- ISO 27001 / CMMI certification will **directly fail**

### ● Risk of accidental superuser:

- Once `is_superuser=True` is set → that account **bypasses all RBAC**
- Including: deleting boss's customers, modifying own salary (if payroll), clearing audit logs
- Removal: another superuser must demote — **if only one superuser exists and they leave → system locked out**

## 1.3 Customer Internal Control Duties (mandatory)

- ☐ Restrict `system.config.update` permission to **owner + 1 IT lead**
- ☐ Establish "new employee account creation" **three-party written approval** (HR + dept manager + IT)
- ☐ Establish "departed employee deactivation" SOP (before end of leaving day)
- ☐ Superuser must have **at least 2** (avoid single-point failure)
- ☐ **Quarterly audit** of inactive / high-privilege account list

## 1.4 Password Initialization

- System enforced: **≥ 8 chars, letters + digits**
- Customer **must inform employee: change password immediately on first login**
- Owner **should not** transmit plaintext password via LINE / Email → use **secure channel**

## 1.5 erpilot Disclaimer

erpilot is **not liable** for security incidents caused by **untimely deactivation**, system lockout from **accidental superuser creation**, or leaks from **improper password transmission**, to the maximum extent permitted by applicable law.

---

## 2. Attach Files to Documents (R3)

### 2.1 Behavior

- Link uploaded Attachment to specified SO / PO / Quote
- Writes `Attachment.parsed_target_type` + `parsed_target_id`

### 2.2 Copyright Risk

- Attachments may contain **third-party copyrighted content** (vendor spec sheets / designs)
- Customer **forwarding** to other third parties requires **license verification**
- Attachments containing **competitor secrets** (mistakenly received email) → should not be retained

### 2.3 PII Risk

- Customer-sent attachments may contain **PII** (contracts / ID copies)
- Subject to PDPA Art. 27 "data security measures"
- Retention should match **statutory retention** (Business Accounting Act §38: 5 years)

### 2.4 Customer Internal Control Duties

- Classify + encrypt attachments
  - **No leakage** (same as v3.36 §2)
  - Periodic cleanup of expired attachments
- 

## 3. AI Per-User Daily Limit (R4)

### 3.1 Behavior

- Middleware intercepts `/api/chat-v2` etc. LLM endpoints
- Default 200 / day / user
- Exceeded → HTTP 429 + friendly Chinese message
- Auto-reset at UTC 00:00

### 3.2 Limits

- **In-memory counter** — backend restart clears
- **Single worker** — multi-worker deployment does not share (v3.x: Redis)
- **Per-IP fallback when no token** — same IP shared by multiple users may misjudge

### 3.3 Configuration

`backend/.env` add:

```
AI_DAILY_LIMIT_PER_USER=500 # default 200
```

### 3.4 Customer Responsibility

- Inform employees of this limit (avoid panic when hit unexpectedly)
- Adjust based on **business needs**
- If employees **often** hit the limit → likely **flow design issue** (not employee fault)

### 3.5 Legal / SLA Impact

- Limit is **heuristic protection**, does **not** replace formal SLA
- Customer **should not** rely solely on this to guarantee "AI won't burn out"
- Still review v3.38 `query_ai_cost_*` for actual usage

## 4. Chat Transcript Export (R6)

### 4.1 Behavior

- Export N days of ConversationLog as markdown
- Contains user role / assistant role / timestamp / agent

### 4.2 Risk

- **Transcript contains user input history**, may include:
  - Customer names / parts / order details (**trade secrets**)
  - Employee's **personal opinions / complaints** in questions (PII + labor law)
  - Password-failed attempts (system shouldn't log, but risk exists)

### 4.3 Customer Internal Control Duties

- **Encrypt** after export
- **Do not** forward to unauthorized personnel
- For **training**: **redact** customer / employee real names
- For **HR evaluation**: **prior notice** to employees (labor law)

### 4.4 erpilot Disclaimer

erpilot is **not liable** for transcript **leak / misuse / use for illegal purposes**.

## 5. Timezone Setting (R7)

### 5.1 Behavior

- Set Tenant.settings.timezone
- LLM responses auto-convert dates/times to this timezone
- DB still stores UTC

### 5.2 Limits

- Whitelist: only common timezones (Asia/Taipei / Tokyo / NY / London / UTC etc.)
- DST handled by Python zoneinfo
- **Does not affect DB UTC storage** (other tools must self-format)

### 5.3 Risk

- Cross-timezone transactions (e.g., customer in EU, factory in TW) → **order date may misjudge**
- Customer should **unify timezone strategy**

## 6. Global Search (R2)

### 6.1 Behavior

- One search across Customers + Parts + Suppliers + Employees
- Case-insensitive, N rows per table

### 6.2 Risk

- Global search may let **low-privilege employees** see **data they shouldn't**
- But **only shows basic fields** (code / name), not amounts / PII details
- Full data still requires per-table query + permission check

### 6.3 Customer Responsibility

- Restrict `user.profile.read` not given to anonymous / temp staff
- Monitor abnormally frequent searches (possible leakage precursor)

## 7. Business Day Calculation (R5)

### 7.1 Behavior

- Add/subtract N business days (auto-skip weekends + Taiwan 2026 holidays)
- Built-in holidays: New Year / Lunar / 2/28 / Tomb Sweeping / Labor / Dragon Boat / Mid-Autumn / Double Tenth

### 7.2 Limits

- 2026 Taiwan holidays only hard-coded
- 2027+ needs manual update (v3.x roadmap: dynamic calendar)
- Excludes company custom holidays (mid-year, year-end)
- Excludes personal leave / comp time

### 7.3 Risk

- Wrong delivery date → customer / supplier dispute
- Customer should manually verify important dates

### 7.4 erpilot Disclaimer

Business day calculation is a **heuristic helper**; erpilot is **not liable** for **contract breach**, **penalties**, **customer complaints** from wrong delivery dates.

---

## 8. Case Studies: Common Misuse

### 8.1 ❌ Don't

- Casually create superusers (no written approval)
- Not deactivate departed employee on same day
- Store competitor attachments mistakenly received
- Screenshot employee complaints from transcript and send to other managers
- Set AI rate limit extremely low (< 50) preventing work

### 8.2 ✅ Do

- Account creation with **three-party approval** (HR + dept manager + IT)
- Deactivate departed employees **before end of leaving day**
- **Virus scan + identify source** before uploading unknown email attachments
- **Redact** sensitive info before using transcript for training

- Set AI rate limit per actual business needs (recommended 200-500)

---

## 9. Disclaimer (Cumulative v3.25.10 → v3.42)

To the maximum extent permitted by applicable law:

1. **User Account Management (R1)** erpilot is **not liable** for security incidents from **untimely deactivation, accidental superuser, improper password transmission, contract disputes, labor disputes.**
2. **Attachments (R3)** erpilot is **not liable** for attachment **copyright compliance, PII protection, competitor info handling.**
3. **AI Daily Limit (R4)** erpilot's limit is **heuristic protection**, does **not** replace formal SLA; **not liable** for business delays from **improper limit settings.**
4. **Transcript Export (R6)** erpilot is **not liable** for transcript leak, misuse, **HR evaluation use disputes.**
5. **Timezone (R7)** erpilot's timezone setting is **display convenience**; **not liable** for **cross-timezone transaction misjudgment losses.**
6. **Global Search (R2)** erpilot's search is **heuristic index**; for **low-privilege staff getting sensitive info**, customer must strengthen RBAC themselves.
7. **Business Days (R5)** erpilot's calculation includes only 2026 Taiwan holidays; **not liable** for **cross-year / company custom holidays miscalculations.**

---

## 10. Pre-Adoption Checklist (v3.42 reinforced)

### 10.1 User Account Management (most critical)

- ☐ Restricted `system.config.update` to owner + 1 IT
- ☐ Established three-party approval SOP for new accounts
- ☐ Established departed employee deactivation SOP (before EOL day)
- ☐ Superuser at least 2 accounts (avoid single point failure)
- ☐ Quarterly audit of inactive / high-privilege accounts

### 10.2 AI Usage Management

- ☐ Informed employees of daily limit
- ☐ Set `AI_DAILY_LIMIT_PER_USER` per business volume
- ☐ Monthly reconciliation of AI cost (use v3.38 `query_ai_cost_*`)

### 10.3 Attachment Management

- ☐ **Defined** attachment classification + encrypted storage SOP
- ☐ **Defined** expired attachment cleanup rules
- ☐ **Trained** employees on identifying suspicious attachments

### 10.4 Transcript Use

- ☐ **Informed** employees: transcript is not for HR appraisal
- ☐ **Defined** sensitive info masking process

### 10.5 Cumulative with Existing Checklists

- ☐ Completed all v3.25.10 → v3.41 checklists

## 11. International / Cross-Border Warning

| Region     | Additional Law                  | Impact on v3.42                                                         |
|------------|---------------------------------|-------------------------------------------------------------------------|
| eu EU      | GDPR Art. 17 (right to erasure) | Deactivation insufficient — employees can demand <b>actual deletion</b> |
| us US      | SOX (public companies)          | Audit log must be <b>tamper-proof</b> — deactivation must be recorded   |
| us US (CA) | CCPA                            | Employees have "data portability" — transcript export must support      |
| cn China   | PIPL                            | Cross-border transcript transfer requires <b>separate consent</b>       |
| jp Japan   | APPI                            | Account status changes must be <b>kept ≥ 3 years</b>                    |

**Version:** v3.42 (2026-05-22) **Author:** erpilot Legal Team (internal) **Corresponds to code:**

- `backend/app/agents/domains/polish_v342_tools.py` (7 LLM tools + helper)
- `backend/app/core/ai_rate_limit.py` (R4 middleware)
- `backend/app/main.py` (middleware wire-in)
- `backend/app/config.py` (AI\_DAILY\_LIMIT\_PER\_USER)
- `frontend-desktop/src/pages/Dashboard.tsx` (R8 mobile)